

TLP:CLEAR

Phishing via Compromised PSL Mailbox

Lovable.app as a landing front, .ru domain as the credential harvester

Phishing | Lovable.app | Compromised mailbox | M365 | PSL.eu

Parameter	Value
Incident date	April 15, 2026, 16:27 UTC
Analysis date	May 3, 2026
Classification	TLP:CLEAR
Threat level	MEDIUM
Type	Phishing / Credential harvesting (two-stage)
Email subject	2026 Amend Proposal YF-W-SW89537
Sender	aissata-keltoum.drame@psl.eu (compromised)
M365 tenant	4f8fd695-b3b5-4082-8005-610e9453e6d0 (Université PSL)
Landing URL	hxxps://amendment-gateway[.]lovable[.]app/
Final URL	hxxps://dotiojea[.]ru/ojEyxTnj@JqGnH/
Final stage	DNS zone removed (NXDOMAIN sentinel) at analysis time

1. Executive Summary

On April 15, 2026 a targeted phishing email was delivered from a legitimate Microsoft 365 mailbox in the Université Paris Sciences & Lettres (PSL, France) tenant. All authentication checks (DKIM, SPF, DMARC) pass for psl.eu — this is not spoofing, it is end-to-end authenticated delivery from a compromised mailbox.

The attack is two-stage. The email leads to a purpose-built landing page on Lovable.app (an AI no-code site builder that hands out free wildcard TLS), and the single «View Proposal» button on that page forwards the victim to the real target — dotiojea.ru, a credential harvester in the .ru zone with a per-victim token in the URL path.

At analysis time the final domain dotiojea.ru no longer responds: DNSPod (Tencent), where it is delegated, has installed a sentinel SOA «nxdomainadmin@dnspod.com» — consistent with abuse takedown or operator self-removal. The Lovable.app landing page remains live.

2. The Lure Email

2.1. Headers and authentication

The email was sent through a real Microsoft 365 outbound server in the French region (PR0P264CU014.outbound.protection.outlook.com, IPv6 2a01:111:f403:c20a::4). The internal hop chain PASP264MB5677 → PR0P264MB3096 (FRAP264.PROD.OUTLOOK.COM) places the tenant in a French datacenter region.

- DKIM: pass (header.i=@psl.eu, selector2, b=ZzQXrxKa)
- SPF: pass (smtp.mailfrom=psl.eu, IP 2a01:111:f403:c20a::4)
- DMARC: pass (domain policy is weak: p=NONE, sp=NONE)
- X-MS-Exchange-CrossTenant-id: 4f8fd695-b3b5-4082-8005-610e9453e6d0 — PSL tenant ID

2.2. Social engineering

The email impersonates a business follow-up to a previous request to sign a document. The body is short and pressures the recipient on missing a response.

- «I wanted to kindly follow up to see if you had a chance to review my last email. I'm still awaiting your assigned signature.»
- Signature: the genuine signature of the PSL employee (Drame Aïssata, Assistante pédagogique 1re année, Collège Sciences, Humanités et Société, Université PSL)
- Subject contains a fake ID («2026 Amend Proposal YF-W-SW89537») — increases trust, complicates subject-based deduplication
- From and To match («to self»), real recipients in BCC — classic mass distribution pattern

3. Stage 1 — Lovable.app Landing Page

The «Access File» CTA in the email is wrapped in a Google redirect (www.google.com/url?q=...) but the final target is hxxps://amendment-gateway.lovable.app/, a page on the Lovable platform (lovable.dev) — an AI no-code single-page app builder. The platform automatically issues each project a subdomain on lovable.app, free TLS, and a Cloudflare front.

3.1. Landing page technical properties

Parameter	Value
URL	hxxps://amendment-gateway[.]lovable[.]app/
Platform	Lovable.dev (AI no-code SPA builder)

Lovable project ID	bb952617-8387-4712-a353-768d866d428a
TLS	wildcard *.lovable.app, Google Trust Services WE1, 2026-04-16 → 2026-07-15
Front	Cloudflare AS13335 (CF-RAY POP WAW)
IP A	185[.]41[.]148[.]1, 185[.]41[.]148[.]2
IP AAAA	2a07:8240::1, 2a07:8240::2
Type	React SPA, single CTA href «View Proposal»
HTML SHA-256	b5fc2252242c74aeb43bce9bc733483a8c79a6792b4eae578ae6c81d570260b7
JS bundle SHA-256	6462db810635dcd49271a491e49af9b481b8acc13be3562341abda7b377200b8

There are no credential-input forms on the landing page itself. It is a «doorway» — the only purpose of the landing tier is to hand the attacker a «clean» domain with trusted TLS that will not be blocked by most enterprise URL filters and will pass cursory scrutiny by the recipient.

3.2. Systematic abuse of the Lovable.app platform

Lovable.app is being actively abused as phishing landing infrastructure since late 2025. Per urlscan.io, more than 230 public scans of lovable.app subdomains have been tagged «phishing». Confirmed neighbouring campaigns using the same pattern (Lovable + free-host final hop):

Subdomain	Date	Brand / theme	Final hop
update-start-hub.lovable.app	2026-04-16	AT&T account update	lisacarswell01.wixsite.com
bet-match-sim.lovable.app	2026-04-10	Sports betting / fraud	lovable self
betinmatch.fr	2026-04-10	Redirect → bet-match-sim	—
punchonsol.lovable.app	2026-02-22	Solana crypto-drainer	—
kamikadigitalbrand.lovable.app	2025-11-13	Brand impersonation	—

4. Stage 2 — Final Target dotiojea.ru

The landing page JS bundle hard-codes a single external href — `hxxps://dotiojea[.]ru/ojEyxTnj@JqGnH/`. This is the campaign's real target, where the credential-harvesting form would be hosted (M365 / DocuSign / Adobe Sign or similar).

4.1. Domain registration data

Parameter	Value
-----------	-------

Domain	dotiojea[.]ru
Registered	2026-03-24 (22 days before the campaign was sent)
Registrar	R01-RU (R01 Holding LLC, RU)
Registrant	Private Person
Status	REGISTERED, DELEGATED, UNVERIFIED
Paid till	2027-03-24
NS (TLD level)	a.dnspod.com, c.dnspod.com (Tencent DNSPod)
Authoritative SOA at analysis	f1g1ns1.dnspod.net / nxdomainadmin@dnspod.com
A / AAAA / MX	— (zone removed after abuse complaints)

4.2. Per-victim tokens and campaign scale

The structure of the final URL is `hxxps://dotiojea[.]ru/{token}/`, where {token} is unique per recipient. Two tokens are currently known:

- `/ojEyxTnj@JqGnH/` — token from the analysed email (recipient `admin@pytkam.net`)
- `/z58!zTjKI/` — token from a public `urlscan.io` scan dated 2026-04-22 (different victim, one week later)

Per-victim tokenisation is a standard tactic of modern AiTM kits (EvilProxy, Tycoon, Mamba 2FA, Caffeine): the per-recipient URL is not handed out to sandbox scanners and is used to track which victim clicked.

5. Attack Chain

1. Compromise of mailbox `aissata-keltoum.drame@psl.eu` (vector unknown; likely AiTM phishing or stolen credentials)
2. Registration of the final-stage domain `dotiojea.ru` (2026-03-24) under a Private Person at R01-RU
3. Creation of the landing page `amendment-gateway.lovable.app` on the Lovable no-code builder (free TLS, Cloudflare front)
4. Lure email sent on 2026-04-15 16:27 UTC through the genuine M365 outbound of the PSL tenant — DKIM/SPF/DMARC pass
5. Recipient clicks the CTA → Google click-tracker → `amendment-gateway.lovable.app`
6. Landing page «View Proposal» button → redirect to `dotiojea.ru/{per-victim-token}/`
7. Victim submits credentials (form unavailable at analysis time; pattern matches M365/DocuSign/Adobe Sign)
8. Post-compromise: lateral phishing inside the academic network, OneDrive/SharePoint access, possible BEC

6. Indicators of Compromise (IOC)

Type	Value
Email subject	2026 Amend Proposal YF-W-SW89537
Compromised sender	<code>aissata-keltoum.drame@psl[.]eu</code>
Tenant ID (M365 PSL)	<code>4f8fd695-b3b5-4082-8005-610e9453e6d0</code>
Outbound MX (M365 FR)	<code>PR0P264CU014.outbound.protection.outlook.com</code> (<code>2a01:111:f403:c20a::4</code>)

EML SHA-256	2d0536dfbbce46c92f588a97da471322bf501111a3eb04d835ffe8e3b84fb70d
Landing URL	hxxps://amendment-gateway[.]lovable[.]app/
Lovable project ID	bb952617-8387-4712-a353-768d866d428a
Landing IP	185[.]41[.]148[.]1, 185[.]41[.]148[.]2 (AS13335 Cloudflare)
Landing JS SHA-256	6462db810635dcd49271a491e49af9b481b8acc13be3562341abda7b377200b8
Final URL #1	hxxps://dotiojea[.]ru/ojEyxTnj@JqGnH/
Final URL #2 (related)	hxxps://dotiojea[.]ru/z58!zTjKI/
Final domain	dotiojea[.]ru (R01-RU, 2026-03-24, UNVERIFIED)
Final NS	a.dnspod.com, c.dnspod.com

7. MITRE ATT&CK

ID	Technique
T1583.001	Acquire Infrastructure: Domains (dotiojea.ru, R01-RU)
T1583.006	Acquire Infrastructure: Web Services (Lovable.app project, free TLS)
T1586.002	Compromise Accounts: Email Accounts (M365 PSL)
T1078.004	Valid Accounts: Cloud Accounts (use of legitimate psl.eu for sending)
T1566.002	Phishing: Spearphishing Link («Access File» CTA)
T1564.011	Hide Artifacts: Hidden URLs (per-victim path token)
T1539	Steal Web Session Cookie (presumed — final harvester)
T1606	Forge Web Credentials (presumed — AiTM kit)

8. Recommendations

8.1. For PSL (Université Paris Sciences & Lettres)

- Reset the password and revoke all refresh/access tokens for aissata-keltoum.drame@psl.eu
- Audit inbox rules / forwarding / OAuth grants — typical attacker follow-ups after AiTM
- Raise the DMARC policy of psl.eu to p=quarantine or p=reject (current p=NONE is insufficient)
- Review Entra ID sign-in logs for atypical geolocations, successful MFA pass-through, new app passwords

- Notify CERT-RENATER (cert@renater.fr)

8.2. For recipients (Google Workspace)

- Run Email log search: identify all recipients by subject «2026 Amend Proposal YF-W-» and Message-ID prefix PASP264MB5677...
- Block in spam filter: amendment-gateway.lovable.app, dotiojea.ru
- Review Workspace audit logs (Gmail/Drive) for anomalous accesses 2026-04-15 → 2026-04-22 for the same users

8.3. Strategic

- Abuse report to Lovable.app (abuse@lovable.dev) referencing project ID bb952617-8387-4712-a353-768d866d428a
- Abuse report to R01-RU (https://partner.r01.ru/contact_admin.khtml) and to RU TLD coordinator (abuse@cctld.ru) — domain status is UNVERIFIED
- Consider categorising *.lovable.app as a no-code site builder on corporate proxies, with raised content rating

TLP:CLEAR — This document may be distributed without restriction.